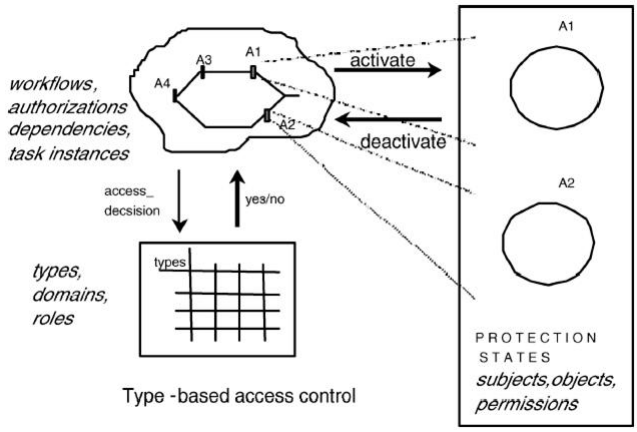
Controlul accesului in sisteme colaborative

Modelele prezentate in continuare reprezinta extensii ale RBAC ce raspund unor cerinte ale sistemelor colaborative: modificarea dinamica a permisiunilor in fluxuri de activitati, controlul accesului pentru echipe de utilizatori, controlul acceslui in functie de context.

TBAC – Task Based Access Control

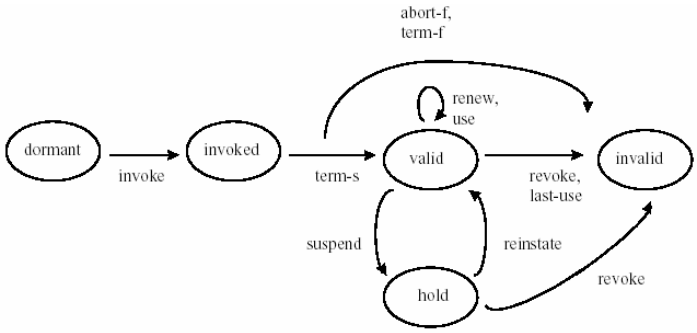
Modelul este adaptat aplicatiilor care constau din fluxuri de activitati (workflows). El tine cont de principiul privilegiilor minime, care cere ca un subiect sa aiba doar acele privilegii care-i permit sa indeplineasca functiile de care este responsabil. In cazul unui flux de activitati, nu trebuie ca toate taskurile sa aiba acelasi set de permisiuni. Fiecare task trebuie sa aiba doar acele permisiuni care-i sunt necesare pentru executia operatiilor asupra obiectele folosite efectiv. Acest set de permisiuni se numeste **Stare de protectie** (Protection state), fiecare stare de protectie reprezentand permisiunile unui anumit task (subiect) asupra unor obiecte specifice. O stare de protectie devine activa la inceputul executiei unui task si este dezactivata la terminarea ei, intr-un proces numit **pas de autorizare** (authorization step). Datorita acestui mod de aplicare a permisiunilor, se spune despre TBAC ca este un model de securitate activa.



Modelul mentine stari de protectie separate si distincte pentru fiecare task si modifica dinamic permisiunile in functie de pasul de autorizare activat la un moment dat.

Pasii de procesare pentru un authorization-step

Ciclu de viata al unui pas de autorizare cuprinde mai multe stari (vezi figura):
- un pas de autorizare este invocat de un task si incepe sa fie prelucrat;
- daca prelucrarea lui se termina cu succes devine valid, altfel invalid
- intr-un pas valid, permisiunile sunt activate si pot fi "consumate"
- permisiunile pot fi suspendate temporar (hold); in acest caz permisiunile sunt temporar inactive si nu pot fi folosite;
- la consumarea permisiunilor (sfarsitul ciclului de viata) pasul de autorizare devine invalid.



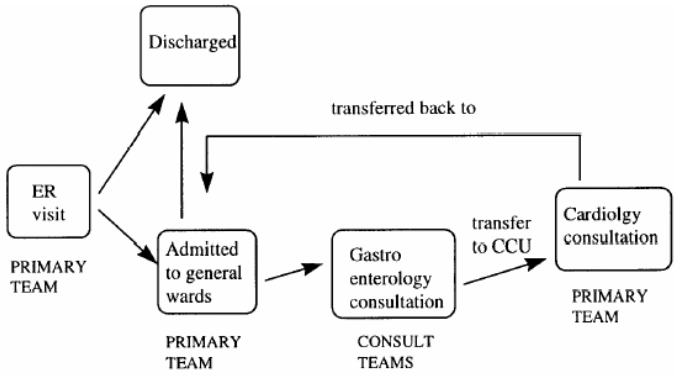
Caracteristici TBAC

TBAC are urmatoarele caracteristici principale:
- Recunoaste notiunea de ciclu de viata si pasii de procesare a autorizarilor;
- Introduce notiunea de consum asociata cu permisiunile (limitarea numarului de accese);
- Formeaza baza auto-administrarii modelului de securitate (administrare cuplata cu activarea si terminarea taskurilor).

Problemele TBAC sunt legate de faptul ca contextul este limitat la relatia cu pasii fluxului de taskuri. De asemenea, exista dificultati in specificarea politicilor complexe, a delegarii si a revocarii privilegiilor

TeaM based Access Control - TMAC

Pentru intelegerea cerintelor modelelor de securitate pentru grupuri de utilizatori, pornim de la un scenariu al unei echipe de medici care ingrijeste un pacient.
Scenariul cuprinde urmatorii pasi:
- pacientul (suferind de pneumonie) vine la camera de garda
- pacientul este consultat si este internat la medicina generala
- echipa care a preluat in ingrijire pacientul decide sa ceara o analiza la gastro-enterologie
- specialistul gastro incepe endoscopia; in timpul analizei are un atac de cord si este transferat la sectia de cardiologie; echipa de la cardiologie devine echipa primara de ingrijire a pacientului;



- dupa tratament, pacientul revine la medicina generala
- pacientul se recupereaza si este eliberat din spital.

Din acest scenariu rezulta urmatoarele elemente:
- personalul este organizat in echipe care ingrijesc bolnavul in diverse etape
- fiecare echipa este asociata unui departament
- membrii echipelor au roluri diferite
- echipele sunt formate dinamic (de exemplu, specialistul gastro-enterolog se alatura echipei de medici generalisti pentru a face consultatia gastro).

Cerinte pentru controlul accesului

Totodata, rezulta urmatoarele cerinte pentru sistemul de control al accesului medicilor la fisa medicala a pacientului:
1. permisiunile asociate unui membru reflecta rolul sau;
de exemplu, cardiologul poate prescrie medicatia pentru atac de cord
2. permisiunile se refera la un anumit pacient (obiect)
astfel, doar membrii echipelor de ingrijire a acestui pacient pot avea acces la fisele sale, iar recomandarea pentru analiza gastro o da medicul generalist din echipa acestui pacient (chiar daca in sectia de medicina generala sunt mai mjulti medici generalisti)
3. accesul este permis in functie de context
de ex., traseul pacientului - echipa de generalisti are acces la fise doar cand pacientul este la medicina generala si un are acces cand pacientul trece la cardiologie si echipa primara se schimba
4. activare colectiva a permisiunilor la executie
cand pacientul trece de la medicina generala la o alta unitate din spital, noua echipa primara are acces la fisa lui, nimeni altcineva
5. membrii pot delega permisiunile
medicul care ingrijeste pacientul poate delega un rezident sa comande un medicament pentru pacient
6. permisiunile pot fi dezactivate
cand pacientul paraseste spitalul, permisiunile de acces la fisele sale inceteaza.

Principalele idei TMAC

In noul model, care incorporeaza notiunea de echipa, sunt introduse urmatoarele elemente relative la echipa:
un nume, t.
un set de membri / team users, TU.
un set de team roles, TR $\subseteq$ R (R = setul total de roluri)
un rol special team head (h), h € TR
un set de tipuri de obiecte, OT
un set de instante de obiecte, O
un set de team permissions TP, TP $\subseteq$ TR x OT
un context de colaborare cu doua componente
    user context (UC), UC : TR x TU
    object context (OC), OC : OT x O
Contextul obiectelor se transmite de la o echipa la alta.

Operational

Sunt definite urmatoarele primitive de grup:
User-assign (user, team): asigneaza user la team.
User-deassign (user, team): inlatura user din team.
Team-activate (team): leaga team permissions la team members si la obiecte (TU si O).

Team-deactivate (team): dezactiveaza permisiunile pentru team.

De asemenea, sunt introduse urmatoarele primitive individuale:
User-activate (user): activare permisiuni individual
User-deactivate (user): dezactivare permisiuni individual

TMAC – Concluzii

TMAC este centrat pe notiunea de echipa, definita ca o colectie de utilizatori cu roluri diferite dar care au ca obiectiv comun indeplinirea unui task.

Permisiunile unui subiect depind de rolul sau si de grupul caruia ii apartine
Permisiunile sunt:

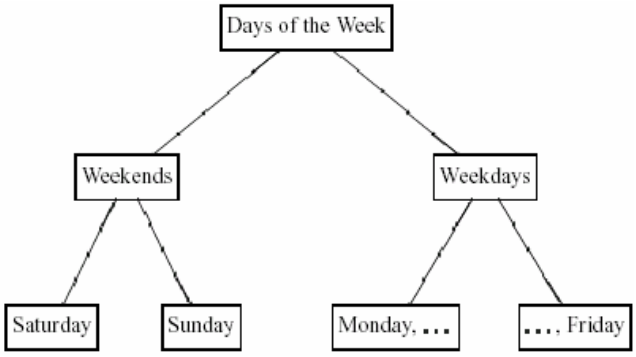
asignate unui rol (ca in RBAC) - model de securitate pasiva;
activate / dezactivate in functie de context - model de securitate activa.

Context-Aware Access Control

Controlul accesului se face in functie de conditiile de mediu:

- timp: acces permis intr-o anumita perioada weekend, weekday
- loc: accesul la un sistem securizat doar daca se face dintr-o incapere securizata fizic
- incarcarea unui sistem: rol high load activat la peste 70%

Modelul extinde RBAC cu roluri de mediu (environment roles) care surprind contextul si sunt activate pe baza conditiilor de mediu. Revocarea unui rol se face cand conditiile nu mai corespund rolului.



Rolurile de mediu au caracteristici comune cu cele clasice:
- evitare conflicte (separarea intereselor)

uneori se doreste activarea unui singur rol la un moment dat;

- ierarhia de roluri (vezi figura de mai sus).

Unele Environment Roles pot fi activate pe durata unei sesiuni, dar schimbarea conditiilor reclama activarea altor roluri.

Modelul

Din RBAC0:
se pastreaza U, R, P si S care capteaza users, roles, permissions si sessions.
Se adauga ER si EC,

ER - *Environment Roles*;
EC - *Environment Conditions* folosite in definirea rolurilor.

Relatiile UA, PA sunt definite astfel:

User Assignment UA $\subseteq$ U x R

Permission Assignment PA $\subseteq$ P x R x 2ER

PA asociaza o permisiune cu rolul unui subiect sio conditioneaza de un set de environment roles ER active.

In plus, urmatoarele functii definesc ce roluri utilizator sau de mediu pot fi activate:
User: S -> 2^{R}

Intr-o sesiune data S, pot fi activate anumite Roluri pentru un User

Request: EC -> 2ER

Pe baza conditiilor de mediu (environmental conditions) de la momentul cererii, se activeaza un set de roluri de mediu (environment roles).

O cerere de permisiune *p poate fi* garantata daca:
(1) p este in setul de permisiuni asociate rolului r, adica <*p, r, e-set*> ϵ PA
(2) Rolul r este in setul de roluri active ale utilizatorului care face cererea
(3) environment roles active in conditiile environmentale curente *EC* contin rolurile din *e-set*.

Bibliografie

R. K. Thomas1 and R. S. Sandhu2 Task-based Authorization Controls (TBAC): A Family of Models for Active and Enterprise-oriented Authorization Management, *Proceedings of the IFIP WG11.3 Workshop on Database Security,Lake Tahoe, California, August 11-13, 1997*

Hong Hai Shen and Prasun Dewan. Access Control for Collaborative Environments, Department of Computer Sciences, Purdue University, West Lafayette, IN 47907, CSCW 92 Proceedings November 1992

WILLIAM TOLONE, GAIL-JOON AHN, TANUSREE PAI, AND SENG-PHIL HONG. Access Control in Collaborative Systems, ACM Computing Surveys, Vol. 37, No. 1, March 2005, pp. 29–41.